Security Monitoring System (AWS)

EXECUTIVE SUMMARY

Overview

This report summarizes the results of the comprehensive implementation of a security monitoring system in our cloud infrastructure.
The implementation focuses on comparing two unique monitoring systems to know the best fit, considering our goals.
The goal of this system is to monitor the **Secrets Manager** service on the AWS cloud infrastructure where database credentials are stored, notify the security team when a breach occurs and potentially block attacker from performing further actions after accessing the “Secret”.

Simulation Result `successful`

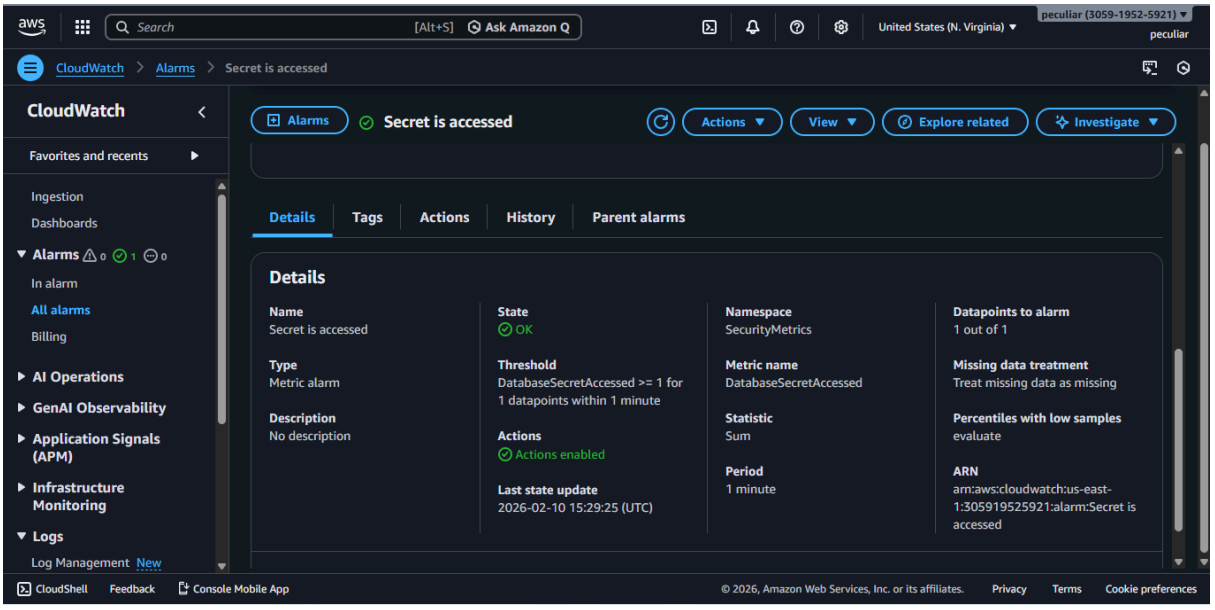
We implemented and compared two monitoring systems;

- Using a Metric Filter
- Using Eventbridge

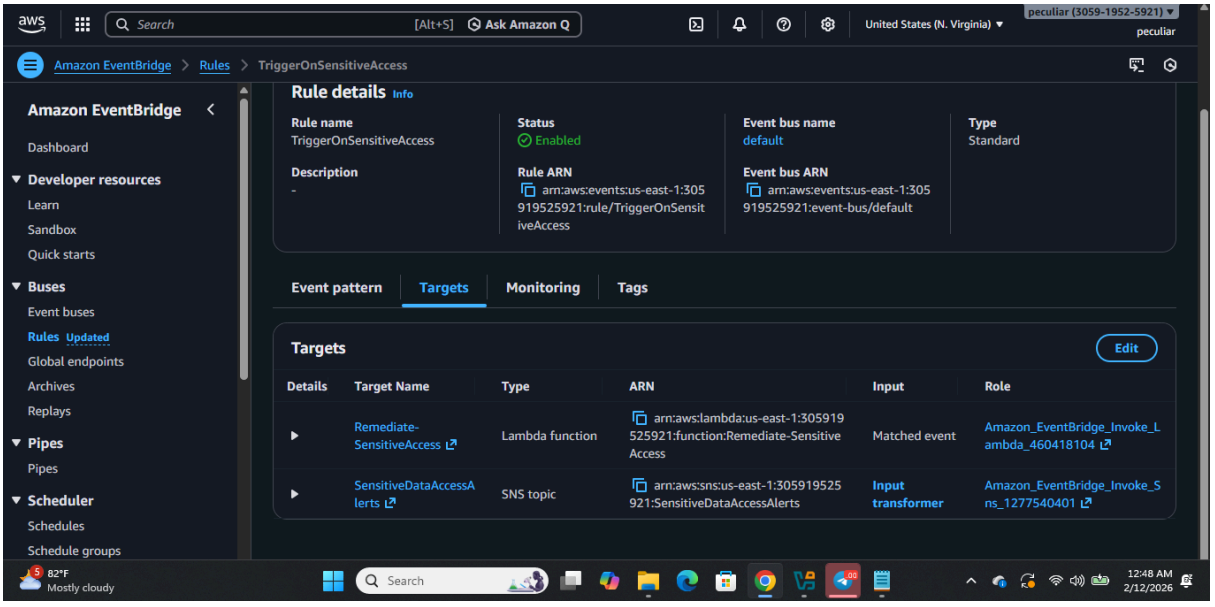
The results from both methods were successful.

LAB ARCHITECTURE

1. **CloudWatch Alarm**



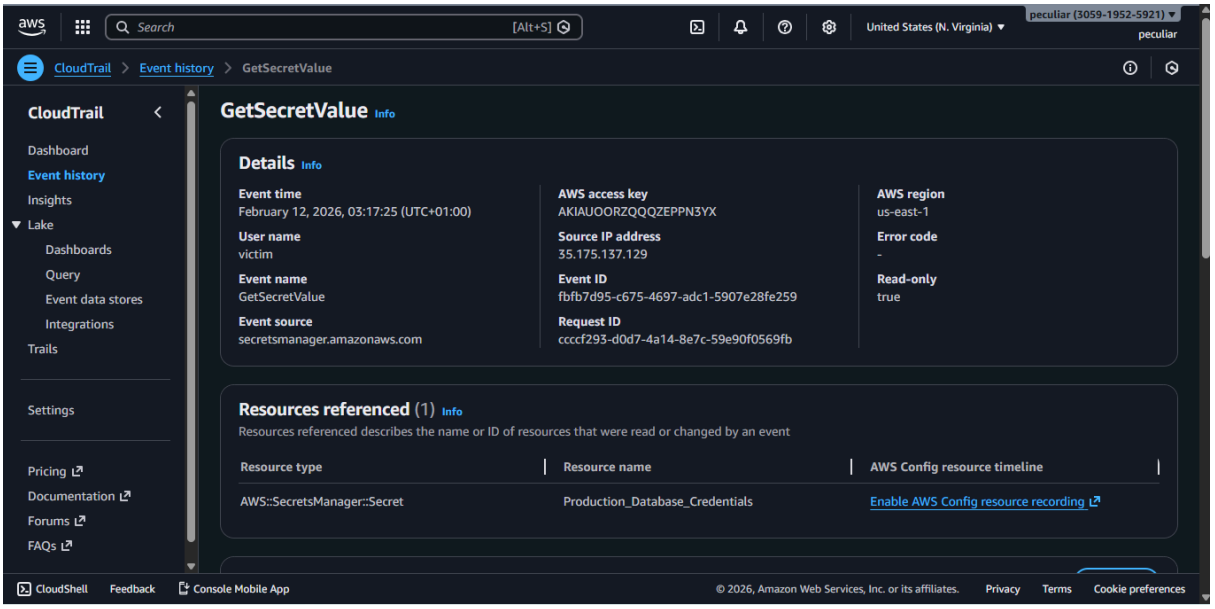
2. **EventBridge Rule**.



The Evidence (Logs)

JSON log from **CloudTrail** showing:

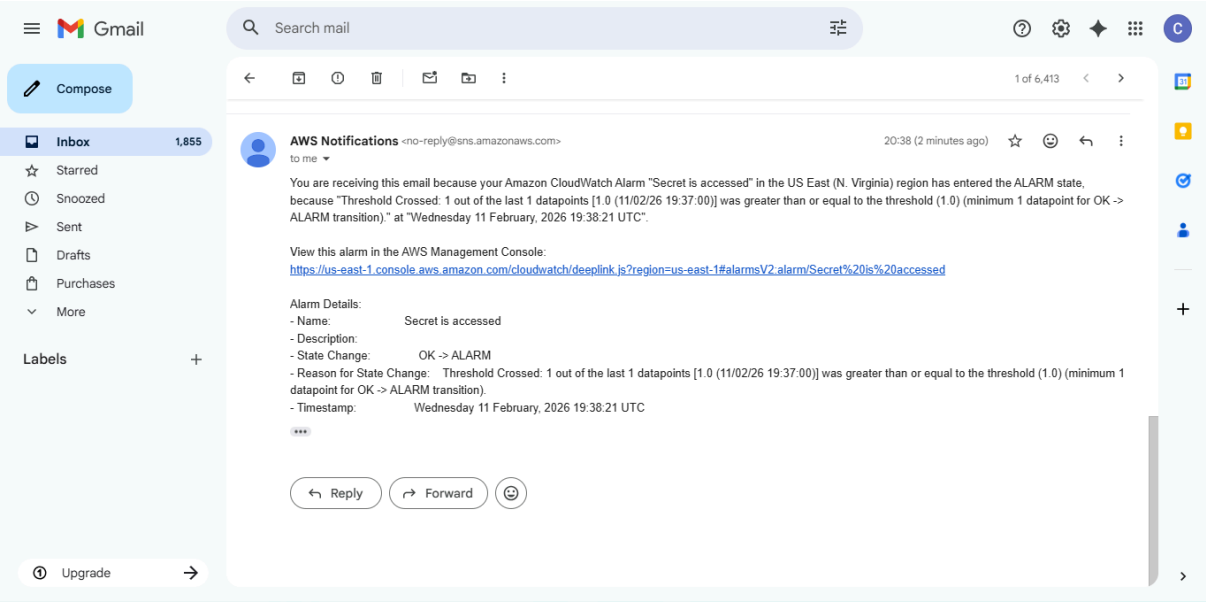
- eventTime
- userIdentity (Who took the secret?)
- sourceIpAddress (Where did the attack come from?)



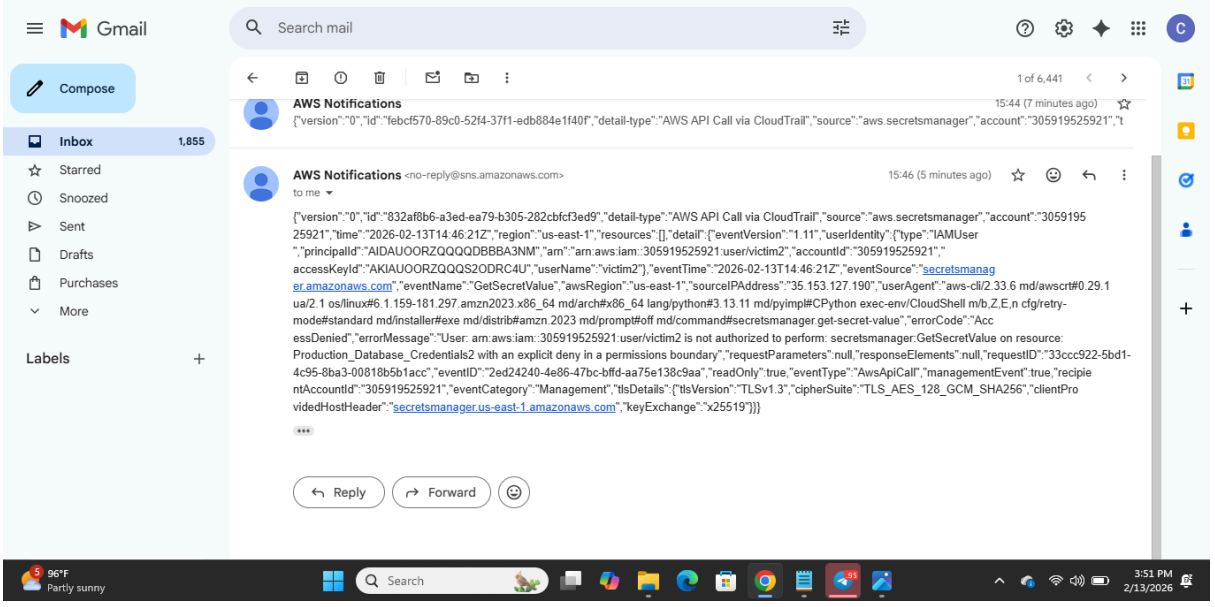
Technical Evidence

1. **The Detection**

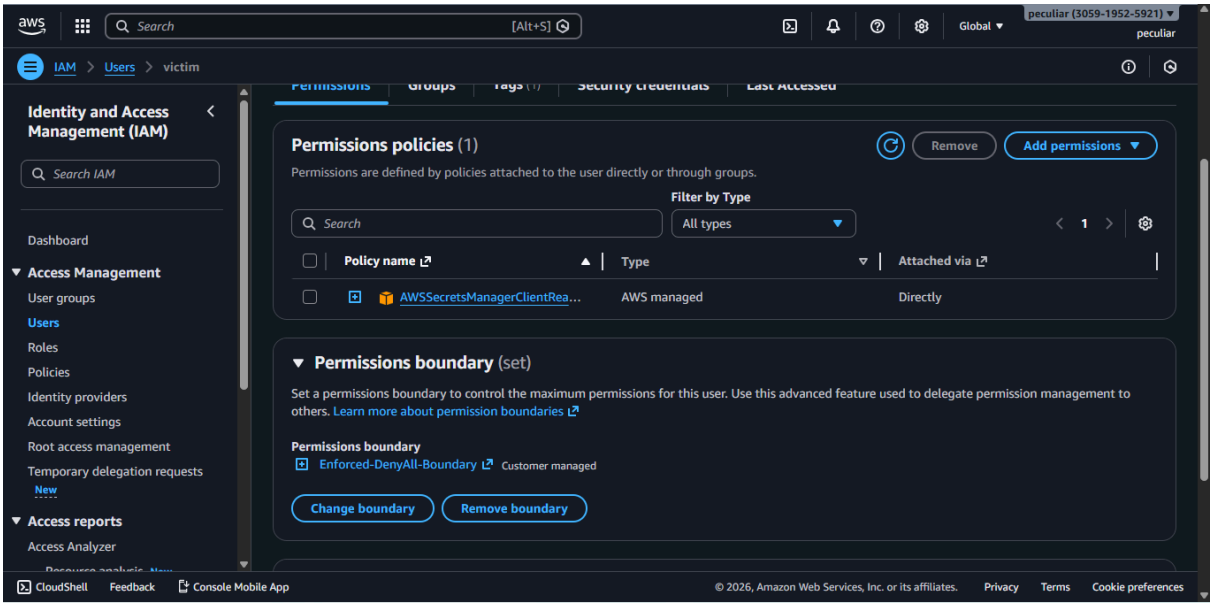
Flow 1 (Metric Filter) email alert



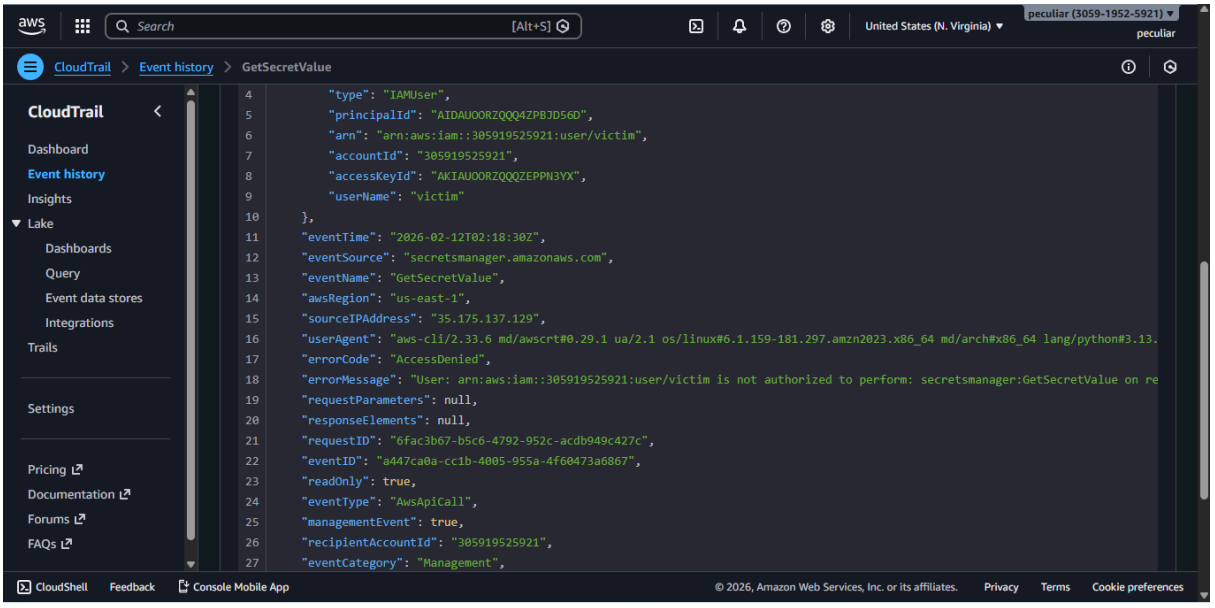
Flow 2 (Eventbridge) email alert



2. **The "Kill-Switch" Proof:** IAM Console showing the "Victim" user is now attached to a **"Quarantine" boundary**



3. **The Log:** A snippet of the CloudTrail JSON showing the errorCode: AccessDenied for the user's second attempt to use the CLI



Security Analysis

- **Speed:**
  Flow 2 (EventBridge) notified me faster. It arrived almost immediately the event was triggered.
  Meanwhile, Flow 1 arrived 2 minutes later.

- **Context:**
  (1) Which alert email provided more useful information (IP address, user name)?
  Flow2 (EventBridge) provides more information, compared to Flow 1

  (2) If you needed to block this user automatically after the alert, what AWS service would you use next?
  I would use AWS Lambda

- **Compliance:** (1) How does this lab satisfy the **Continuous Monitoring** requirement of a framework like **NIST**?

  This lab satisfies the Continuous Monitoring requirements of the NIST framework by;
  1. **Definition:** Developed a Continuous Monitoring strategy based on risk tolerance (identifying what metrics to track and how often). (**Secrets**

Manager).
2. Establishment: Create the Continuous Monitoring program (**CloudTrail)**
3. Implementation: Deploy the monitoring tools and data collection processes (**CloudTrail and CloudWatch**).
4. **Analysis & Report:** Examine the collected data to identify trends and security gaps. (**CloudWatch Alarm, EventBridge Rule and SNS Notification)**
5. Response: Implement remediation actions based on the analysis. **(Lambda Functions or Manual remediation after alert is received)**

Lessons Learned

If I were to improve this system for a bank, I would prefer the **EventBridge (Flow 2)** for triggering the Kill-Switch because;

1. **Real-Time Response** : In a bank, if an attacker inappropriately accesses a "Secret" (like a database credential or an API key for a payment gateway), every second that key remains active is a liability.
   A SOC analyst would see an alert, investigate, and then manually disable the user. This takes minutes or hours. Meanwhile, EventBridge triggers the **SSM Automation** and **Lambda** instantly. The attacker is locked out before they can even use the secret they just retrieved.

2. **Compliance with PCI DSS : Requirement 10** of PCI DSS mandates tracking and monitoring all access to network resources and sensitive data. Eventbridge provides an automated "Audit Trail." Because EventBridge logs the trigger and the Lambda logs the execution, the bank can prove to auditors that they have **automated technical controls** to protect sensitive keys.